

Bug Bounty Learning Roadmap

From Fresher to Bug Hunter

A comprehensive guide covering every topic you need to learn, with realistic hour estimates for each — from foundational networking to advanced exploitation techniques.

Estimated Total: 2,500 – 4,500 hours | 12–18 months (full-time)

Table of Contents

1. Phase 1: Foundations (200–285 hrs)
2. Phase 2: OWASP Top 10 Core Vulnerabilities (778–1,213 hrs)
3. Phase 3: Tools & Reconnaissance (145–222 hrs)
4. Phase 4: Intermediate Vulnerabilities (621–1,084 hrs)
5. Phase 5: Advanced Topics (885–1,606 hrs)
6. Phase 6: Report Writing & Strategy
7. Quick Reference — Easiest to Hardest (Ranked)
8. Suggested Learning Order
9. Grand Total & Timeline Summary
10. Key Resources

Phase 1: Foundations (2–3 months / 200–285 hours)

These are prerequisites — you won't find bugs with them alone, but you can't hunt without them.

#	TOPIC	LEARN (HRS)	PRACTICE (HRS)	TOTAL
1	Networking Basics (TCP/IP, DNS, HTTP/HTTPS, Cookies, Sessions)	30–40	20–30	**50–70**
2	Linux Fundamentals (CLI, File System, Permissions, Bash Scripting)	25–35	20–30	**45–65**
3	Web Technologies (HTML, CSS, JavaScript, Browser Internals)	40–60	30–40	**70–100**
4	How Web Apps Work (Client-Server, REST APIs, Auth Flows, Sessions vs Tokens)	20–30	15–20	**35–50**

Phase 2: OWASP Top 10 Core Vulnerabilities (3–4 months / 778–1,213 hours)

The bread and butter of bug bounty. Master these first.

#	VULNERABILITY	LEARN (HRS)	LABS (HRS)	HUNTING (HRS)	TOTAL
5	**Cross-Site Scripting (XSS)** — Reflected, Stored, DOM-based	25–35	30–40	80–120	**135–195**
6	**SQL Injection (SQLi)** — Classic, Blind, Time-based	20–30	25–35	100–150	**145–215**
7	**Cross-Site Request Forgery (CSRF)**	8–12	10–15	30–50	**48–77**
8	**Insecure Direct Object Reference (IDOR)**	6–10	10–15	25–40	**41–65**
9	**Broken Authentication** (Password Reset Flaws, Session Fixation, Brute Force)	15–25	20–30	60–100	**95–155**
10	**Broken Access Control** (Privilege Escalation — Horizontal & Vertical)	12–18	15–25	50–80	**77–123**
11	**Security Misconfiguration** (Exposed Panels, Default Creds, Dir Listing)	5–8	8–12	20–40	**33–60**
12	**Server-Side Request Forgery (SSRF)**	12–18	15–25	80–120	**107–163**
13	**XML External Entity (XXE)**	6–10	8–12	60–100	**74–122**
14	**Open Redirect**	3–5	5–8	15–25	**23–38**

Phase 3: Tools & Reconnaissance (1–2 months / 145–222 hours)

Good recon is half the bug. These tools expand your attack surface.

#	TOOL / TECHNIQUE	LEARN (HRS)	PROFICIENCY (HRS)	TOTAL
15	**Burp Suite** (Intercepting, Repeater, Intruder, Scanner)	20–30	40–60	**60–90**
16	**Subdomain Enumeration** (subfinder, amass, assetfinder)	8–12	15–20	**23–32**
17	**Directory / Content Discovery** (ffuf, dirsearch, gobuster)	5–8	10–15	**15–23**
18	**Google Dorking** (Exposed Files, Login Panels, Sensitive Data)	3–5	8–12	**11–17**
19	**Shodan / Censys / crt.sh** (Passive Recon)	5–8	8–12	**13–20**
20	**Nuclei & Automation** (Template-Based Scanning)	8–15	15–25	**23–40**

Phase 4: Intermediate Vulnerabilities (2–3 months / 621–1,084 hours)

These require deeper understanding and creative thinking.

#	VULNERABILITY	LEARN (HRS)	LABS (HRS)	HUNTING (HRS)	TOTAL
21	**Business Logic Flaws** (Price Manipulation, Race Conditions, Coupon Abuse)	15–25	20–30	80–150	**115–205**
22	**API Security Testing** (REST, GraphQL — Broken Auth, Mass Assignment)	25–35	25–35	60–100	**110–170**
23	**File Upload Vulnerabilities** (RCE via Upload, Filter Bypass)	8–12	10–15	50–80	**68–107**
24	**Command Injection / RCE**	8–15	10–20	80–150	**98–185**
25	**Subdomain Takeover**	4–6	5–8	20–40	**29–54**
26	**CORS Misconfiguration**	5–8	8–12	25–40	**38–60**
27	**Host Header Injection**	3–5	5–8	20–35	**28–48**
28	**HTTP Request Smuggling**	15–25	20–30	100–200	**135–255**

Phase 5: Advanced Topics (3–6 months / 885–1,606 hours)

High-severity findings. These take time but pay the most.

#	VULNERABILITY	LEARN (HRS)	LABS (HRS)	HUNTING (HRS)	TOTAL
29	**OAuth / SSO Vulnerabilities** (Token Theft, Redirect Manipulation)	20–30	20–30	80–150	**120–210**
30	**JWT Attacks** (None Algorithm, Key Confusion, Claim Tampering)	10–15	12–18	50–100	**72–133**
31	**Prototype Pollution** (JavaScript-Specific)	10–15	12–18	80–150	**102–183**
32	**Server-Side Template Injection (SSTI)**	8–15	10–18	80–150	**98–183**
33	**Deserialization Attacks**	15–25	20–30	100–200	**135–255**
34	**Race Conditions** (TOCTOU)	8–12	10–15	50–100	**68–127**
35	**Cache Poisoning**	15–20	15–25	100–200	**130–245**
36	**Mobile App Testing** (Android/iOS — Decompiling, Intercepting, Cert Pinning)	40–60	40–60	80–150	**160–270**

Phase 6: Report Writing & Program Strategy

#	TOPIC	TIME	NOTES
37	**Writing Quality Reports** (Steps to Reproduce, Impact, PoC)	10–15 hrs	Improve with every report you submit
38	**Choosing Programs** (Start with VDPs → Paid; Large Scope)	Ongoing	Critical for success — scope matters more than skill
39	**Reading Disclosed Reports** (HackerOne Hacktivity, Bugcrowd)	30 min/day	The single best habit for learning real-world bugs

Quick Reference — Easiest to Hardest (Ranked by Total Hours)

RANK	TOPIC	TOTAL HOURS	DIFFICULTY
1	Open Redirect	23–38	EASY
2	Subdomain Takeover	29–54	EASY
3	Host Header Injection	28–48	EASY
4	CORS Misconfiguration	38–60	EASY
5	IDOR	41–65	EASY
6	CSRF	48–77	EASY
7	Security Misconfiguration	33–60	EASY
8	JWT Attacks	72–133	MEDIUM
9	Race Conditions	68–127	MEDIUM
10	Broken Authentication	95–155	MEDIUM
11	File Upload Vulnerabilities	68–107	MEDIUM
12	Broken Access Control	77–123	MEDIUM
13	SSRF	107–163	MEDIUM
14	XSS (Reflected, Stored, DOM)	135–195	MEDIUM
15	API Security	110–170	MEDIUM
16	XXE	74–122	MEDIUM
17	Business Logic Flaws	115–205	MEDIUM
18	SQL Injection	145–215	HARD
19	SSTI	98–183	HARD
20	Prototype Pollution	102–183	HARD
21	OAuth / SSO	120–210	HARD
22	Command Injection / RCE	98–185	HARD
23	HTTP Request Smuggling	135–255	EXPERT
24	Cache Poisoning	130–245	EXPERT
25	Deserialization	135–255	EXPERT
26	Mobile App Testing	160–270	EXPERT

Suggested Learning Order

> **Start hunting on real programs by month 2–3.** Most beginners over-study and under-hunt. Spend 70% hunting, 30%

> learning new topics.

TIMELINE	FOCUS TOPICS	WHY
Week 1–8	IDOR + Broken Access Control	Most beginner-friendly; common in real apps
Week 8–14	XSS (Reflected → Stored → DOM)	High volume of targets; always in scope
Week 14–18	CSRF + Open Redirect	Quick wins; good for building confidence
Week 18–24	Business Logic + API Testing	Scanners miss these; human creativity needed
Month 7+	SSRF, Auth Bugs, Race Conditions	Medium–High severity; bigger payouts
Month 10+	Smuggling, SSTI, Deserialization	Critical findings; expert-level payouts

Grand Total & Realistic Timeline

Total Hours by Phase

PHASE	HOURS
1. Foundations	200–285
2. OWASP Top 10	778–1,213
3. Tools & Recon	145–222
4. Intermediate	621–1,084
5. Advanced	885–1,606
GRAND TOTAL	**2,500–4,500**

Time to Complete (All Topics)

DAILY COMMITMENT	DURATION
4 hours / day	20–37 months
6 hours / day	14–25 months
8 hours / day (full-time)	10–18 months

Milestones

MILESTONE	TIME
First valid bug (IDOR/XSS on VDP)	3–6 months
Consistent valid findings	8–12 months
Medium/High severity bugs	12–18 months
Critical/Advanced bugs	18–36 months

You don't need all topics to start earning. Master the top 6 easiest ones (~200–350 hours / 2–3 months at 4 hrs/day) and start hunting on real programs immediately.

Key Resources

Practice Platforms

PortSwigger Web Security Academy — Free, structured labs (start here)

OWASP Juice Shop — Intentionally vulnerable web app

HackTheBox — Machines & challenges

TryHackMe — Guided learning paths

PentesterLab — Hands-on exercises

YouTube Channels

NahamSec — Bug bounty tips & recon

STOK — Bug bounty methodology

InsiderPhD — Beginner-friendly walkthroughs

LiveOverflow — Deep technical exploits

John Hammond — CTF & security

Books

The Web Application Hacker's Handbook — Stuttard & Pinto

Bug Bounty Bootcamp — Vickie Li

Real-World Bug Hunting — Peter Yaworski

Bug Bounty Platforms

HackerOne — Largest platform; read Hacktivity daily

Bugcrowd — Good beginner programs

Intigriti — European platform

YesWeHack — Growing platform

The #1 accelerator: Read disclosed reports on HackerOne Hacktivity for 30 minutes every day. You'll learn more real-world patterns than any course can teach.